title: "Record Keeping, Confidentiality & GDPR Policy" version: "1.0" effectiveDate: "[Insert Date]" reviewDate: "[Insert Date – usually annually]" appliesTo: "All staff, contractors, volunteers, and residents at [INSERT CARE HOME NAME]"

Record Keeping, Confidentiality & GDPR Policy

1. Policy Statement

At [INSERT CARE HOME NAME], we are committed to maintaining accurate, secure, and confidential records in line with the UK General Data Protection Regulation (UK GDPR), the Data Protection Act 2018, and the CQC Fundamental Standards.

We aim to:

- Protect the privacy, dignity, and rights of residents, staff, and visitors.
- Ensure records are accurate, up to date, and accessible to those with a legitimate need.
- Comply with all statutory and regulatory requirements for data protection.
- Promote a culture of accountability, transparency, and confidentiality.

2. Purpose

This policy provides guidance on:

- Standards for record keeping (paper and electronic).
- Confidentiality of personal and sensitive information.
- Responsibilities under UK GDPR and data protection law.
- Secure storage, sharing, and disposal of records.
- Resident and staff rights regarding their data.

3. Scope

This policy applies to:

- All staff, agency staff, and volunteers handling records or personal data.
- All resident records, including health, care, and administrative files.
- Personnel records for staff and contractors.
- All electronic and paper-based records held by the care home.

4. Roles and Responsibilities

Registered Manager (Data Controller):

- Ensures compliance with GDPR and data protection legislation.

- Oversees secure storage, retention, and disposal of records.
- Ensures staff receive data protection and confidentiality training.
- Reports and records any data breaches in line with ICO guidance.

Data Protection Officer (if appointed):

- Provides specialist advice on GDPR compliance.
- Monitors and audits data protection practices.
- Acts as point of contact for the Information Commissioner's Office (ICO).

All Staff:

- Maintain accurate, clear, and timely records.
- Respect confidentiality of residents, colleagues, and organisational information.
- Access and share information only when necessary and lawful.
- Report concerns about data handling or breaches immediately.

5. Record Keeping Standards

- Records must be factual, accurate, relevant, and written in a respectful manner.
- Entries must be dated, timed, and signed (or electronically logged).
- Amendments must not obscure original entries; corrections must be clear.
- Records must be updated promptly after care or significant events.

6. Confidentiality

- All personal and sensitive information will be treated as confidential.
- Information is shared strictly on a need-to-know basis.
- Staff must not discuss resident or staff information outside of professional contexts.
- Confidential information must not be disclosed without consent, unless required by law or safeguarding duties.

7. GDPR and Data Protection

- All personal data will be:
    - Processed lawfully, fairly, and transparently.
    - Collected for specific, explicit, and legitimate purposes.
    - Adequate, relevant, and limited to what is necessary.
    - Accurate and kept up to date.
    - Kept only as long as necessary.
    - Processed securely.
- Residents and staff have the right to:
    - Access their personal data.
    - Request correction of inaccurate data.
    - Request deletion of their data (where legally appropriate).
    - Restrict or object to certain types of processing.
    - Data portability (where applicable).

8. Data Storage and Security

- Paper records kept in locked cabinets with restricted access.
- Electronic records password-protected and access-controlled.
- Regular system backups and secure IT systems maintained.
- Portable devices encrypted and used only when necessary.

- Confidential documents not left unattended or visible to unauthorised persons.

9. Retention and Disposal

- Records retained in line with NHS Records Management Code of Practice and legal requirements.
- Care records typically kept for 8 years after death or discharge (longer if safeguarding concerns apply).
- Staff records retained for 6 years after employment ends.
- Records securely shredded or permanently deleted once retention period expires.

10. Breach Management

- Any actual or suspected data breach must be reported immediately to the Registered Manager / Data Protection Officer.
- Serious breaches reported to the ICO within 72 hours.
- Incident reviews carried out and lessons learned implemented.

11. Training and Awareness

- All staff receive confidentiality and GDPR training at induction.
- Annual refresher training required.
- Updates provided when legislation or best practice changes.

12. References

- UK General Data Protection Regulation (UK GDPR)
- Data Protection Act 2018
- NHS Records Management Code of Practice
- Care Quality Commission (CQC) Fundamental Standards – Regulation 17 (Good Governance)
- Information Commissioner's Office (ICO) Guidance

13. Related Policies

- Safeguarding Adults Policy
- Information Security Policy
- Complaints Policy
- Staff Conduct & Disciplinary Policy
- Resident Rights Policy

Generated by Docuflow